

Concepto de auditoría

Clases de auditoría

Según la norma ISO 19011 (IRAM-ISO 19011:2012), la auditoría es un proceso sistemático, independiente y documentado para obtener y evaluar de manera objetiva las evidencias con el fin de determinar la extensión en la que se cumplen los requisitos de auditoría.

Auditorías internas

Denominadas en algunos casos auditorías de primera parte, se realizan por la propia organización, o en su nombre, para la revisión por la dirección y para otros propósitos internos (por ejemplo, para confirmar la eficacia del sistema de gestión o para obtener información para la mejora del sistema de gestión). Las auditorías internas pueden formar la base para una autodeclaración de conformidad de una organización. En muchos casos, particularmente en organizaciones pequeñas, la independencia puede demostrarse al estar libre el auditor de responsabilidades en la actividad que se audita o al estar libre de sesgo y conflicto de intereses.

Auditorías externas

Incluyen auditorías de segunda y tercera parte. Las auditorías de segunda parte se llevan a cabo por partes que tienen un interés en la organización, tal como los clientes, o por otras personas en su nombre. Las auditorías de tercera parte se llevan a cabo por organizaciones auditoras independientes, tales como las autoridades reglamentarias o aquellas que proporcionan la certificación.

Cuando dos o más organizaciones auditoras cooperan para auditar a un único auditado, se lo denomina “auditoría conjunta”.

Definiciones de auditoría

Se refiere a la actividad a fin de comprobar y revisar, actos administrativos, registraciones contables, operaciones financieras a fin de dar la razonabilidad de estas respaldadas por documentación o criterios de aceptación general.

Asimismo, es la actividad de emitir una opinión profesional sobre si el objeto en análisis presenta adecuadamente la realidad que pretende reflejar o cumple las condiciones que fueron definidas.

Alcance

Incluye generalmente una descripción de las ubicaciones, las unidades de la organización, las actividades y los procesos, así como el período de tiempo cubierto.

Misión

Evaluar y monitorear la efectividad de los sistemas de controles internos para proporcionar una seguridad razonable en cuanto al logro de:

- Efectividad y eficiencia de las operaciones (Desempeño y rentabilidad).
- Confiabilidad de la información contable (Cuidadosa consideración y aprobación en tiempo oportuno).
- Cumplimiento de las leyes y normas aplicables (Disposiciones legales y reglamentaciones de la entidad).
- Integrar comités (Auditoría con seguridad de la información).

Definiciones de control interno

Control

Son las políticas, procedimientos, prácticas y estructuras organizacionales diseñadas para garantizar razonablemente que los objetivos del negocio serán alcanzados y que eventos no deseables serán prevenidos o detectados y corregidos.

Objetivos de control de TI

Definición del resultado o propósito que se desea alcanzar implementando procedimientos de control en una actividad de TI particular.

Control interno

Es un proceso llevado a cabo por el Consejo de Administración, la gerencia junto a otro personal diseñado para proporcionar una garantía razonable sobre el logro de objetivos relacionados con operaciones, informes y cumplimiento (COSO). También, se lo considera un conjunto de todos los métodos coordinados y medidas adoptadas dentro de una empresa, con el fin de:

- Resguardar activos.
- Asegurar la confiabilidad y corrección de los datos (que reflejen la realidad).
- Promover la eficacia y eficiencia operativa de los actos administrativos.
- Fomentar la adhesión a las políticas, normas y procedimientos administrativos internos (procesos administrativos).

Principios generales de control interno

1. Mantener sistemas de control de alta calidad.
2. Responsabilidad de “la gestión” de mantenerlos y responsabilidad de “la línea” de ejecutarlos.
3. El alcance de los procedimientos debe ser equiparables al riesgo.
4. A mayor tamaño de la empresa, mayor necesidad de contar con un esquema de control interno definido.

Clasificación del control interno

Preventivos

Permiten acotar la posibilidad de desvío respecto de lo planeado antes de que suceda.

Detectivos

A través de acciones de vigilancia o monitoreo que permitan detectar desvíos y corregir errores.

Correctivos

Ocurrido un desvío permiten corregirlo.

Limitaciones

- El control interno debe responder a la relación costo beneficio (el valor del control de lo que se quiere proteger).
- Es normal que el control interno se dirija a actos administrativos del tipo repetitivos, no incluye tareas infrecuentes.
- No existen sistemas perfectos.

- El control interno puede fallar si las personas que integran el mecanismo de control se ponen de acuerdo para cometer irregularidades (colusión).

Evolución de la auditoría

La auditoría de sistemas es una sección o área que tiene participación en la etapa de análisis de necesidades informáticas, en el desarrollo del software, ya sea interno o contratado a terceros, en su implementación y durante la explotación de estos.

Es la encargada de evaluar el control periódico de las instalaciones, de los equipos de telecomunicaciones, de las políticas de resguardo, etc., ejerciendo un juicio profesional, sólido y maduro para evaluar los procedimientos que deben seguirse y observar los resultados obtenidos, informando acerca de su accionar periódicamente a la Alta Dirección de la empresa con total imparcialidad.

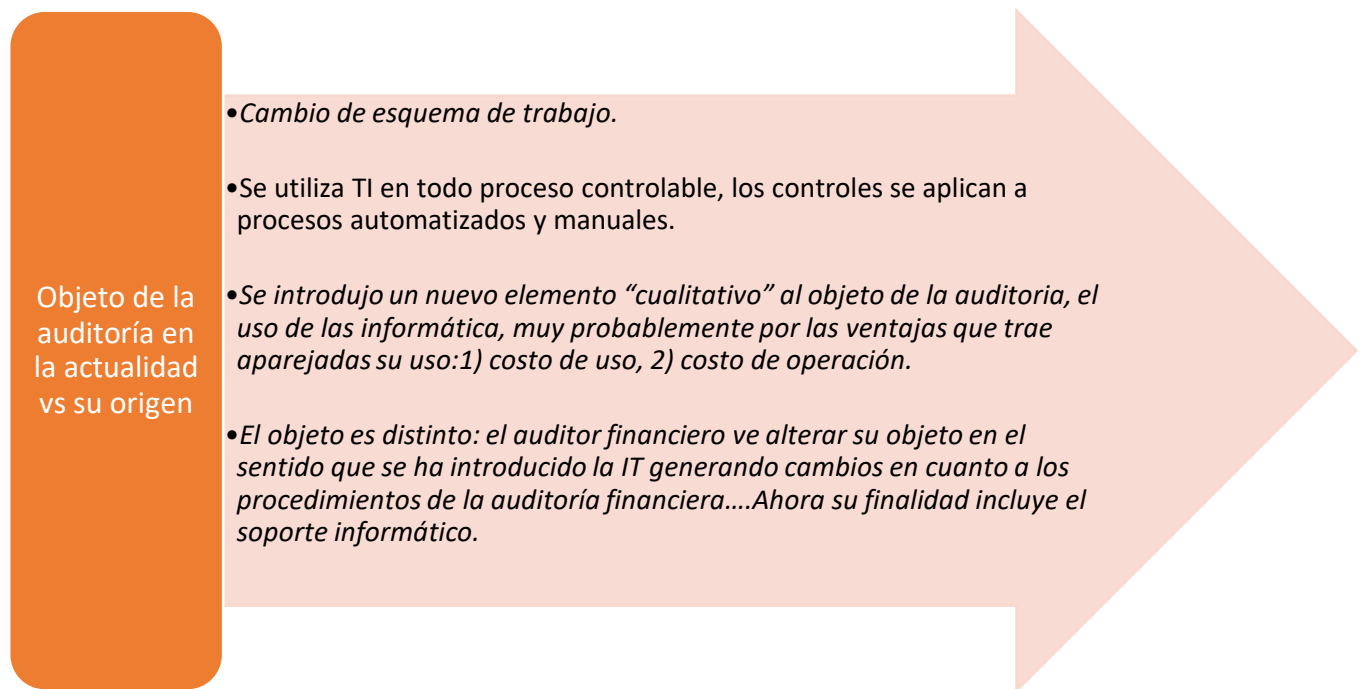


Figura 1: Evolución de la Auditoría. Fuente: elaboración propia.

En la actualidad, las auditorías de TI incluyen:

- Aproximación de auditorías basadas en riesgos.
- Uso de herramientas y técnicas informáticas.
- Uso de estándares, ISO/IEC 27000, ISO 9000 y 27002.

- Comprender los roles del negocio y expectativas en los sistemas desarrollados o adquiridos.
- Evaluación de la seguridad de la información y temas de privacidad.
- Examinar y verificar que la organización cumpla con todos los requisitos legales y normativos aplicables.
- Reportes de gestión y ejecución de proyectos.
- Tecnologías utilizadas que involucran, Internet, Intranet, intercambio de datos, telecomunicaciones, telefonía IP, etc., así como el software, el hardware que les dan soporte a sus procesos y funciones.

La auditoría se caracteriza por depender de principios (ISO 19011):

1) Integridad

El fundamento de la profesionalidad: los auditores y las personas que gestionan un programa de auditoría deberían:

- Desempeñar su trabajo con honestidad, diligencia y responsabilidad;
- Observar y cumplir todos los requisitos legales aplicables;
- Demostrar su competencia al desempeñar su trabajo;
- Desempeñar su trabajo de manera imparcial, es decir, permanecer ecuánime y sin sesgo en todas sus acciones;
- Ser sensible a cualquier influencia que se pueda ejercer sobre su juicio mientras lleva a cabo una auditoría.

2) Presentación imparcial

La obligación de informar con veracidad y exactitud: los hallazgos, conclusiones e informes de la auditoría deberían reflejar con veracidad y exactitud las actividades de auditoría. Se debería informar de los obstáculos significativos encontrados durante la auditoría y de las opiniones divergentes sin resolver entre el equipo auditor y el auditado. La comunicación debería ser veraz, exacta, objetiva, oportuna, clara y completa.

3) Debido cuidado profesional

La aplicación de diligencia y juicio al auditar: los auditores deberían proceder con el debido cuidado, de acuerdo con la importancia de la tarea que desempeñan y la confianza depositada en ellos por el cliente de la auditoría y por otras partes interesadas. Un factor

importante al realizar su trabajo con el debido cuidado profesional es tener la capacidad de hacer juicios razonados en todas las situaciones de la auditoría.

4) Confidencialidad

Seguridad de la información: los auditores deberían proceder con discreción en el uso y la protección de la información adquirida en el curso de sus tareas. La información de la auditoría no debería usarse inapropiadamente para beneficio personal del auditor o del cliente de la auditoría, o de modo que perjudique el interés legítimo del auditado. Este concepto incluye el tratamiento apropiado de la información sensible o confidencial.

5) Independencia

La base para la imparcialidad de la auditoría y la objetividad de las conclusiones de la auditoría: los auditores deberían ser independientes de la actividad que se audita siempre que sea posible, y en todos los casos deberían actuar de una manera libre de sesgo y conflicto de intereses. Para las auditorías internas, los auditores deberían ser independientes de los responsables operativos de la función que se audita. Los auditores deberían mantener la objetividad a lo largo del proceso de auditoría para asegurarse de que los hallazgos y conclusiones de la auditoría estarán basados sólo en la evidencia de la auditoría.

Para las organizaciones pequeñas, puede que no sea posible que los auditores internos sean completamente independientes de la actividad que se audita, pero deberían hacerse todos los esfuerzos para eliminar el sesgo y fomentar la objetividad.

6) Enfoque basado en la evidencia

El método racional para alcanzar conclusiones de la auditoría fiables y reproducibles en un proceso de auditoría sistemático. La evidencia de la auditoría debería ser verificable. En general se basará en muestras de la información disponible, ya que una auditoría se lleva a cabo durante un período de tiempo delimitado y con recursos finitos. Debería aplicarse un uso apropiado del muestreo, ya que está estrechamente relacionado con la confianza que puede depositarse en las conclusiones de la auditoría.

Definición de su entorno y alcance dentro de las organizaciones

Dentro de las organizaciones, el Área de Auditoría pasa por distintas etapas en su ejecución:



Figura 2: Fases de la Auditoría. Fuente: elaboración propia.

Al auditar, las revisiones persiguen los siguientes propósitos:

- Comprobar que las actividades se realizan conforme a las normas.
- Normas y procedimientos están actualizados.
- Los resultados obtenidos son razonables.
- Formular recomendaciones que llevan a mejorar debilidades del control interno.

Objetivos de la auditoría relacionados con la operación.	Existencia: el objetivo es asegurar que lo registrado haya realmente ocurrido.
	Integridad: el objetivo es que todas las operaciones correspondiente a una actividad se hayan registrado.
	Precisión o exactitud: los valores con los que se debe registrar son los correctos.
	Clasificación: las categorías en las que se registra son las correctas.
	Tiempo: las operaciones se realizan en los momentos que corresponden.
	Asentamiento y resumen: las operaciones se realizan en los todos los archivos que corresponden.

Figura 3: La Auditoría y la Operación. Fuente: elaboración propia.

Referencias

- Piattini, M. y Del Paso, E. *Auditoría Informática: Un enfoque práctico* (Capítulo 2: “Control Interno y Auditoría Informática”).
- IRAM / ISO 19011:20112 – Directrices para la auditoría de los sistemas de gestión.

COBIT:

- COBIT 5 ISACA® Framework - © 2012 ISACA. All rights reserved. For usage guidelines, see www.isaca.org/COBITuse. Procesos Catalizadores.
- <https://www.isaca.org/>